CONTROLIT

PERMIT TO WORK MANAGEMENT PLATFORM

Permit to Work Management Platform

Security, Data Storage & Privacy Statement

Version 1.1 | November 2026 | getcontrolit.com

CONFIDENTIAL

CONFIDENTIAL

Table of Contents

1. About CONTROLIT 2
2. Where Is Your Data Stored? 3
3. Security Architecture 4
4. Data Privacy 5
5. AI Features 6
6. Permit Document Generation 7
7. Infrastructure & Hosting 8
8. Compliance & Standards 9
9. Incident Response 9
10. Availability & Uptime 9
11. Contact & Data Requests 10
12. Summary for Decision Makers 10

1. About CONTROLIT

CONTROLIT is a cloud-based digital Permit to Work (PTW) management platform designed for HSE professionals, site managers, area authorities, safety officers, and operations teams working in construction, oil & gas, petrochemical, energy, mining, and other high-risk industrial environments.

CONTROLIT digitises the entire permit lifecycle — from request through multi-stage approval, mandatory field verification, issuance, extension, and closure — with real-time SIMOPS conflict detection, AI-powered risk assessment, role-based access control, and a complete immutable audit trail on every permit.

2. Where Is Your Data Stored?

Cloud Infrastructure

All CONTROLIT data is stored on Supabase, an enterprise database platform built on PostgreSQL — the same database technology trusted by organisations including Apple, Instagram, and the International Space Station.

Data Centres

- Supabase operates on Amazon Web Services (AWS) infrastructure
- Data is hosted in highly available, redundant data centres
- Data is replicated across multiple availability zones — no single point of failure
- Regional hosting options available on request for data residency requirements

Backups

- Automatic daily backups retained for a minimum of 7 days
- Point-in-time recovery — data can be restored to any specific moment
- Backups stored in geographically separate locations from primary data
- No permit data, audit trail, or user record is ever permanently lost due to hardware failure

Permit & Audit Data Storage

- All permit records, approval logs, field verification checklists, and audit trail entries stored in Supabase's managed PostgreSQL database
- Printed permit PDFs are generated client-side — no permit documents are transmitted to or stored on external servers
- All data is encrypted at rest and in transit
- Each organisation's data is fully isolated from all other organisations on the platform

3. Security Architecture

Authentication

- Industry-standard email and password authentication secured with Supabase Auth
- Sessions managed with JWT (JSON Web Tokens) with automatic refresh and expiry
- All authentication traffic encrypted over TLS 1.3
- Invite-only access model — no user can self-register without an explicit invitation from an organisation administrator

Invite-Only Access

- CONTROLIT operates a strict invite-only access model at the organisation level

- New organisations are onboarded by the CONTROLIT platform owner only — no public sign-up
- Within each organisation, team members are invited exclusively by the organisation's Admin
- Each invite is tied to a specific email address, role, and organisation
- Invites can be revoked at any time by the organisation Admin or platform owner

Role-Based Access Control (RBAC)

CONTROLIT enforces strict role-based permissions across the entire permit workflow:

Role	Capabilities
Requester	Raise and submit permit requests. View own permits and audit trail.
Area Authority	Review and approve permits at stage 2. Confirm area readiness and SIMOPS clearance.
HSE Manager	Review HSE compliance, risk assessment adequacy, and approve at stage 3.
HSE Officer	Conduct on-site field verification, sign off checklist, and issue permits at stage 4.
Admin	Full organisation access — invite team members, manage roles, suspend users, view all permits and audit trails.

Row-Level Security (RLS)

- Every database table is protected by Supabase Row-Level Security policies
- Policies are enforced at the database level — not just the application level
- Even if the application code were compromised, the database would still enforce access rules
- No user can ever access permit data, audit trails, or profiles from another organisation

Data Isolation

- Each organisation's data is completely isolated at the database level using a unique org_id on every record
- Organisation A cannot see, access, or query any data belonging to Organisation B
- This isolation is enforced by cryptographic user identity (UUID) — not just application logic
- The platform owner has read-only visibility across organisations for operational oversight — no permit actions can be taken from the owner dashboard

Encryption

- All data in transit encrypted using TLS 1.2 / TLS 1.3 (HTTPS)
- All data at rest encrypted using AES-256 encryption
- SSL certificates issued and automatically renewed via GitHub Pages
- The CONTROLIT domain (getcontrolit.com) enforces HTTPS-only — HTTP connections are automatically redirected

4. Data Privacy

What Data We Collect

CONTROLIT collects only the minimum data necessary to operate the platform:

- **Account data:** Full name, email address, role, organisation

- **Permit data:** Permit type, work description, location, form fields, validity period, status, approvals
- **Audit data:** Timestamped action logs, approver names, roles, sign-off notes
- **Field verification data:** Checklist items, HSE Officer digital sign-off, site remarks
- **Activity data:** Login timestamps, permit status updates, approval timestamps

What We Do NOT Collect

- No payment card information
- No biometric data
- No GPS or location tracking
- No device identifiers beyond what the browser provides
- No data is sold or shared with third parties for advertising purposes

Data Ownership

- Your organisation owns your data — at all times
- CONTROLIT does not claim ownership of any permit data, audit trails, or documents generated on the platform
- Data export is available on request

Data Retention

- Active organisation data is retained for the duration of the subscription
- Upon account closure, data is retained for 30 days before permanent deletion
- Users may request immediate deletion of their personal data at any time
- Permit audit trails are treated as immutable records — deletions are logged

GDPR Compliance

CONTROLIT is designed with GDPR principles in mind:

- **Lawful basis:** Data is processed only to deliver the contracted service
- **Data minimisation:** Only necessary data is collected
- **Right to access:** Users can request a copy of their data at any time
- **Right to erasure:** Users can request deletion of their personal data
- **Data portability:** Permit data can be exported in standard formats on request

5. AI Features

CONTROLIT includes an optional AI-powered risk assessment feature that generates key hazards, precautionary controls, and emergency procedures for each permit based on its type, work description, and area.

- AI risk assessments are powered by Anthropic Claude via a secure API call
- Permit data (type, title, area) is sent to the AI API over an encrypted HTTPS connection
- No permit data is stored or used for AI model training by the AI provider
- AI queries are stateless — each request is independent with no memory of previous queries
- Use of the AI risk assessment feature is optional — all risk fields can be completed manually
- The AI API key is stored securely within the application — not exposed to end users

6. Permit Document Generation

CONTROLIT includes a built-in permit document generation feature that produces professional, print-ready permit documents directly from live permit data once a permit has been issued.

How It Works

- Once a permit is issued by the HSE Officer (following mandatory on-site field verification), a Print permit button becomes available
- Clicking the button instantly generates a professionally formatted permit document in the browser
- The permit document includes all approval chain details, field verification checklist, HSE Officer sign-off, validity window, and a legal notice footer
- Documents are generated client-side — no permit document data is transmitted to external servers during generation
- The generated permit can be printed and must be posted at the job site for the duration of work

Permit Document Contents

- Permit ID, type, and title
- Work area and location
- Requester name, supervisor name, and team details
- Full approval chain with approver names and timestamps (Requester → Area Authority → HSE Manager → HSE Officer)
- Pre-work field verification checklist with all items confirmed
- HSE Officer digital sign-off name and timestamp
- Permit validity window
- Legal compliance notice and job site posting requirement

7. Infrastructure & Hosting

CONTROLIT is hosted on GitHub Pages with Supabase as the backend database and authentication layer.

Platform	Role	Status
GitHub Pages	Primary production hosting — global CDN, automatic SSL, instant deployments	**Active**
Cloudflare DNS	Domain management for getcontrolit.com — DNS resolution and HTTPS enforcement	**Active**
Supabase / AWS	Database, authentication, row-level security, and real-time subscriptions	**Active**
Anthropic API	AI-powered risk assessment — stateless, encrypted API calls per permit	**Active**

8. Compliance & Standards

CONTROLIT's infrastructure providers maintain the following certifications:

Provider	Certifications

Supabase / AWS	SOC 2 Type II, ISO 27001, ISO 27017, ISO 27018, GDPR compliant
GitHub Pages	SOC 2 Type II, GDPR compliant
Cloudflare	SOC 2 Type II, ISO 27001, GDPR compliant
Anthropic (AI)	Enterprise-grade AI safety infrastructure, GDPR compliant

PTW Regulatory Alignment

- CONTROLIT's 4-stage approval workflow is benchmarked against the ADNOC Permit to Work standard
- The mandatory field verification checklist requirement aligns with OSHA and ISO 45001 PTW best practices
- SIMOPS conflict detection supports compliance with simultaneous operations management requirements
- The immutable audit trail supports regulatory inspection, incident investigation, and legal compliance requirements
- The 2-extension limit per permit enforces best-practice permit validity management

9. Incident Response

In the event of a security incident:

- Affected organisations will be notified within 72 hours of discovery
- A full incident report will be provided including scope, impact, and remediation steps
- CONTROLIT maintains an incident response approach aligned with ISO 27035 guidelines
- In the event of a hosting platform issue, the application can be redeployed to an alternative platform within minutes — the Supabase database remains unaffected and fully operational

10. Availability & Uptime

- CONTROLIT targets 99.9% uptime for all production services
- The Supabase database layer operates independently of the hosting platform — data is always accessible
- Real-time status monitoring is in place for all critical components
- Supabase maintains a published status page at status.supabase.com
- GitHub Pages status is published at githubstatus.com

11. Contact & Data Requests

For any security concerns, data access requests, or privacy enquiries:

CONTROLIT Support

hello@getcontrolit.com

getcontrolit.com

Data requests are acknowledged within 48 hours and fulfilled within 30 days.

12. Summary for Decision Makers

Concern	CONTROLIT Answer
Where is data stored?	AWS-backed Supabase cloud — enterprise grade
Is data backed up?	Yes — daily automatic backups with point-in-time recovery
Who can access our data?	Only invited members of your organisation — enforced at database level
Can other companies see our data?	No — complete cryptographic isolation between organisations
Is data encrypted?	Yes — AES-256 at rest, TLS 1.3 in transit
Is it GDPR compliant?	Yes — designed with GDPR principles
How is AI handled securely?	Via encrypted API call — permit data is not stored or used for training
Can we generate permit documents?	Yes — print-ready branded permit documents generated instantly after issuance
Does the system meet PTW standards?	Yes — benchmarked against ADNOC PTW standard and aligned with ISO 45001
What if the hosting platform goes down?	Supabase database remains active — application can be redeployed within minutes
What if there's a breach?	72-hour notification, full incident report
Do you sell our data?	Never
Who owns the data?	Your organisation — always

This document was prepared by CONTROLIT and is accurate as of November 2026.
For the most current version please visit getcontrolit.com or contact hello@getcontrolit.com